Sicurezza dei Sistemi Informativi

Appello d'Esame del 18 Febbraio 2022

Anno Accademico 2021-2022

Politecnico di Torino — Docente: Prof. Cataldo Basile

2022-02-18

1 Testo Ufficiale dell'Esame

Domanda 1: Trattamento Dati, Proprietà e Ruoli secondo il GDPR

Spiegare cosa è un trattamento dei dati personali e quali proprietà e principi devono essere garantiti, secondo il Regolamento Generale sulla Protezione dei Dati (GDPR), per ogni operazione di trattamento. Spiegare inoltre che ruolo hanno e quali sono le principali funzioni e responsabilità delle seguenti figure:

a. Titolare del trattamento (Data Controller);

b. Responsabile del trattamento (Data Processor);

c. Incaricati / persone autorizzate al trattamento;

d. Responsabile della Protezione dei Dati (Data Protection Officer - DPO).

Domanda 2: Standard di Sicurezza ITSEC (Classi A vs B)

Spiegare quale è il requisito metodologico e tecnico fondamentale che differenzia la classe B dalla classe A nel sistema di certificazione e valutazione europea ITSEC (Information Technology Security Evaluation Criteria). Illustrare la gerarchia dei criteri di correttezza ed efficacia e il ruolo dei modelli formali di sicurezza.

Domanda 3: Modello Man-at-the-End (MATE)

Indicare cosa è e cosa prevede il modello Man-at-the-End (MATE) per gli attacchi contro il software. Descrivere gli obiettivi dell'attaccante, i vettori di attacco più comuni e spiegare quali misure di protezione software (offuscamento, anti-debugging, watermarking) possono essere impiegate, commentandone i limiti teorici e pratici.

Domanda 4: Crittografia Simmetrica e Modalità Operative

Dati gli algoritmi di cifratura simmetrica a blocchi, confrontare le modalità operative CBC (Cipher Block Chaining) e CTR (Counter Mode). Discutere in particolare:

- Gestione del vettore di inizializzazione (IV) e nonce;
- Parallelizzabilità delle operazioni di cifratura e decifratura;
- Propagazione degli errori sul canale (in caso di corruzione di bit o perdita di pacchetti);

- Requisiti di padding del testo in chiaro.

Domanda 5: Esercizio di Segmentazione e Firewalling

Un'organizzazione universitaria deve proteggere la propria infrastruttura di laboratorio. Sono definite tre zone:

- **Zona Studenti**: `10.0.1.0/24` (connessa via Wi-Fi ed ethernet di laboratorio);
- **Zona Server**: `10.0.2.0/24` (ospita server web `10.0.2.10` e database interno `10.0.2.20`);
- **Zona Gestione/Docenti**: `10.0.3.0/24`.

Requisiti:

1. Gli studenti possono accedere solo al Web Server su porta 80 e 443;
2. Il Web Server può accedere al Database interno su porta TCP 5432 (PostgreSQL); nessun altro può accedere al Database direttamente;
3. La Zona Gestione può amministrare via SSH (TCP 22) tutti i server e accedere ad Internet;
4. Gli studenti e la Zona Gestione possono accedere liberamente ad Internet (HTTP/HTTPS);
5. Nessun traffico proveniente dall'esterno (Internet) può accedere a nessuna zona interna, tranne che al Web Server se esposto (tramite NAT/port forwarding);
6. Compilare la tabella delle regole del firewall con politica di default DROP.

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: GDPR — Trattamento, Principi e Figure

Definizione di Trattamento (Art. 4 GDPR): Qualsiasi operazione o insieme di operazioni, compiute con o senza l'ausilio di processi automatizzati e applicate a dati personali o insiemi di dati personali, come la raccolta, la registrazione, l'organizzazione, la strutturazione, la conservazione, l'adattamento o la modifica, l'estrazione, la consultazione, l'uso, la comunicazione mediante trasmissione, diffusione o qualsiasi altra forma di messa a disposizione, il raffronto o l'interconnessione, la limitazione, la cancellazione o la distruzione.

Principi Fondamentali del Trattamento (Art. 5 GDPR):

- **Liceità, correttezza e trasparenza**: I dati devono essere trattati in modo lecito e comprensibile per l'interessato.
- **Limitazione della finalità**: I dati devono essere raccolti per finalità determinate, esplicite e legittime.
- **Minimizzazione dei dati**: I dati raccolti devono essere adeguati, pertinenti e limitati a quanto strettamente necessario per le finalità dichiarate.
- **Esattezza**: I dati devono essere esatti e, se necessario, aggiornati tempestivamente.
- **Limitazione della conservazione**: Conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità.
- **Integrità e riservatezza**: Garantire un'adeguata sicurezza mediante misure tecniche e organizzative idonee contro trattamenti non autorizzati, perdita o distruzione.
- **Responsabilizzazione (Accountability)**: Il titolare del trattamento deve essere in grado di comprovare il rispetto di tutti i principi precedenti.

Ruoli e Funzioni nel GDPR:

- **Titolare del trattamento (Data Controller)**: La persona fisica o giuridica che determina le finalità e i mezzi del trattamento dei dati personali. Ha la responsabilità primaria e legale della conformità al GDPR, dell'adozione di misure di *Privacy by Design* e *by Default*, e della notifica dei *Data Breach* all'autorità garante entro 72 ore.
- **Responsabile del trattamento (Data Processor)**: Soggetto esterno che tratta dati personali per conto del Titolare sulla base di un contratto vincolante (es. fornitore di servizi cloud hosting).
- **Incaricati / Persone Autorizzate**: I dipendenti o collaboratori interni che, operando sotto la diretta autorità del titolare o del responsabile, hanno accesso ai dati ed eseguono le mansioni strettamente assegnate.
- **Data Protection Officer (DPO)**: Figura indipendente con competenze specialistiche, nominata obbligatoriamente in enti pubblici o grandi aziende. Il DPO ha compiti di consulenza, monitoraggio della conformità al regolamento e funge da punto di contatto sia per gli interessati che per l'Autorità Garante. Non è responsabile in solido dei risarcimenti (che ricadono sul Titolare).

Soluzione Domanda 2: ITSEC — Differenza tra Classe A e Classe B

Il Criterio Differenziante fondamentale: Nello standard europeo ITSEC (Information Technology Security Evaluation Criteria), la valutazione della correttezza (*Correctness*) è strutturata in livelli da E1 a E6 (ereditati poi dai Common Criteria con gli EAL). Nel modello gerarchico delle classi di sicurezza (ereditato dal modello TCSEC statunitense e raffinato in ITSEC):

- **Classe B (Mandatory Protection)**: Si basa su una politica di controllo accessi di tipo *Mandatory Access Control (MAC)*. Il sistema impone l'etichettatura degli oggetti con livelli di classificazione (es. Top Secret, Secret, Unclassified) e dei soggetti con nulla osta di sicurezza (Clearance). La correttezza del sistema è dimostrata tramite una specifica rigorosa e l'aderenza a modelli di sicurezza riconosciuti (es. modello Bell-LaPadula per la confidenzialità o Biba per l'integrità). Tuttavia, la specifica e la dimostrazione sono condotte con metodi semi-formali e test intensivi.
- **Classe A (Verified Protection)**: Rappresenta il livello massimo di garanzia. Il requisito tecnico e metodologico che differenzia in modo categorico la classe A dalla classe B è l'obbligo di utilizzare **metodi e modelli matematici formali di verifica**:
  1. Presenza di un **Formal Top-Level Specification (FTLS)**: la specifica delle funzionalità del Trusted Computing Base (TCB) deve essere formulata in un linguaggio logico-matematico formale.
  2. **Dimostrazione formale di correttezza**: è richiesta la prova matematica formale che la specifica FTLS soddisfi rigorosamente il modello formale di politica di sicurezza.
  3. Tracciabilità rigorosa e verificabile matematicamente tra il codice sorgente/eseguibile implementato e le specifiche formali approvate.
  4. Analisi formale approfondita dei *Covert Channels* (canali di comunicazione clandestini sia temporali che di memorizzazione).

Soluzione Domanda 3: Modello Man-at-the-End (MATE)

Il Modello MATE: Nel modello MATE, l'avversario ha il controllo completo della macchina fisica e dell'ambiente operativo:

- *Obiettivi dell'attaccante*: Rimozione dei meccanismi di licenza/DRM, estrazione di algoritmi proprietari (reverse engineering per concorrenza industriale), scoperta di vulnerabilità zero-day non divulgate, estrazione di chiavi crittografiche cablate nel codice, manomissione della logica di esecuzione (es. bypass di controlli di sicurezza in cheat per gaming o moduli bancari).
- *Vettori di attacco*: Analisi statica (disassemblatori Ghidra/IDA Pro), analisi dinamica tramite tracing (GDB, Frida, eBPF), dump di memoria runtime, modifica statica dei binari (patching di istruzioni di salto condizionale, es. da `JZ` a `JNZ`).

Contromisure Software e Limiti:

1. **Offuscamento**: Trasformazione del codice per distruggere le astrazioni ad alto livello, rendere il grafo del flusso di controllo (CFG) irriconoscibile e confondere gli algoritmi di decompilazione.

2. **Anti-Debugging & Anti-Tampering**: Utilizzo di routine che rilevano la presenza di debugger (`ptrace`, verifica del registro `PEB.BeingDebugged` in Windows, verifica di interrupt software `INT 3`), auto-verifica con hashing del segmento di codice a runtime.

3. **Watermarking**: Incorporamento di un marchio segreto per certificare la provenienza e dimostrare la violazione del copyright in tribunale.

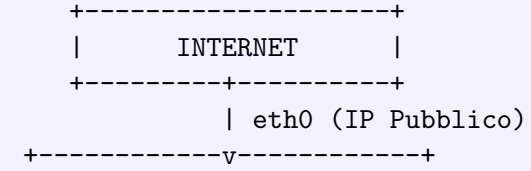
Valutazione dei limiti: Qualsiasi istruzione che una CPU deve eseguire deve necessariamente risiedere in chiaro nei registri e nella pipeline del processore a un certo istante temporale. Pertanto, un attaccante sufficientemente determinato, dotato di risorse e tempo, potrà sempre neutralizzare protezioni puramente software. La difesa punta sull'innalzamento del *Work Factor*.

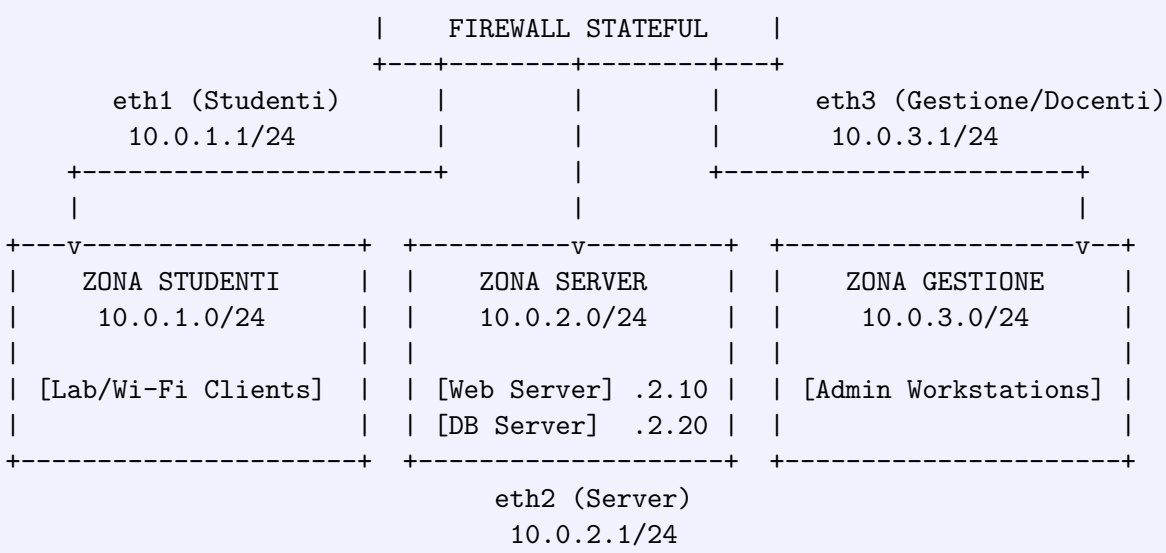
Soluzione Domanda 4: Crittografia Simmetrica — CBC vs CTR

Caratteristica	CBC (Cipher Block Chaining)	CTR (Counter Mode)
Funzionamento	Ogni blocco di plaintext subisce uno XOR con il blocco di ciphertext precedente: $C_i = E_K(P_i \oplus C_{i-1})$, con $C_0 = IV$.	Si cifra un contatore incrementale $CTR_i = Nonce \parallel i$. Il ciphertext si ottiene come $C_i = P_i \oplus E_K(CTR_i)$.
Requisito IV / Nonce	L'IV deve essere **casuale e imprevedibile** (unpredictable). Se predicibile, è soggetto a chosen-plaintext attack.	Il nonce deve essere **unico per ogni messaggio** (mai riutilizzato con la stessa chiave), ma non deve necessariamente essere segreto o impredicibile.
Parallelizzazione	**Sequenziale in cifratura** (richiede C_{i-1} per calcolare C_i). **Parallelizzabile in decifratura** ($P_i = D_K(C_i) \oplus C_{i-1}$).	**Completamente parallelizzabile sia in cifratura che in decifratura**. Consente inoltre il *random access* a blocchi arbitrari.
Propagazione Errori	Un errore di bit nel blocco C_i corrompe completamente P_i e inverte lo stesso bit in P_{i+1}, ma l'errore non si propaga oltre P_{i+1} (auto-sincronizzante a 2 blocchi).	Un errore di bit in C_i corrompe esattamente ed esclusivamente il corrispondente bit in P_i. Non vi è alcuna propagazione ad altri blocchi.
Padding	**Obbligatorio**: la lunghezza del messaggio deve essere multiplo della dimensione del blocco (es. PKCS#7 padding da 1 a 16 byte).	**Non richiesto**: trasforma il cifrario a blocchi in uno stream cipher. L'ultimo blocco parziale viene semplicemente troncato.

Soluzione Domanda 5: Tabella di Filtraggio Firewall per il Laboratorio

Architettura e Segmentazione di Rete: La rete universitaria è suddivisa in quattro zone distinte controllate da un firewall stateful multiporta:





Subnetting IP e Instradamento:

- `eth0` **(Internet)**: Connessione WAN esterna. Applica Source NAT (SNAT) per il traffico originato dalle sottoreti Studenti e Gestione verso Internet, e Destination NAT (DNAT) per l'accesso pubblico al Web Server (`10.0.2.10`).
- `eth1` **(Studenti,** `10.0.1.0/24`**)**: Gateway `10.0.1.1`. Può accedere solo a Web Server (80, 443) e Internet; isolata da DB e Gestione.
- `eth2` **(Server,** `10.0.2.0/24`**)**: Gateway `10.0.2.1`. Ospita Web Server (`10.0.2.10`) e PostgreSQL DB (`10.0.2.20`). Il DB non ha accesso ad Internet né può avviare connessioni verso le altre zone.
- `eth3` **(Gestione,** `10.0.3.0/24`**)**: Gateway `10.0.3.1`. Può gestire tutti i server via SSH (porta 22) e accedere ad Internet.

Tabella Regole (Default Policy: DROP):

ID	Dir	Src IP	Dst IP	Proto	Port	State	Azione & Spiegazione
1	Any	Any	Any	Any	Any	ESTABLISHED, RELATED	**ACCEPT**: Risposte del traffico bidirezionale
2	In/Fwd	10.0.1.0/24	10.0.2.10	TCP	80, 443	NEW	**ACCEPT**: Studenti accedono al Web Server
3	In/Fwd	10.0.2.10	10.0.2.20	TCP	5432	NEW	**ACCEPT**: Web Server interroga il Database
4	In/Fwd	10.0.3.0/24	10.0.2.0/24	TCP	22	NEW	**ACCEPT**: Docenti/Admin amministrano i server via SSH
5	In/Fwd	10.0.1.0/24	Any (Internet)	TCP	80, 443	NEW	**ACCEPT**: Studenti

Alternative Implementation Note: Strutture Rust per la Gestione del Firewall

In un'implementazione ad alte prestazioni di un packet filter o firewall stateful scritta in linguaggio Rust:

- `std::sync::RwLock<HashMap<ConnectionTuple, ConnectionState>>`: La *state table* delle connessioni (basata sulla tupla a 5 elementi: IP src, IP dst, porta src, porta dst, protocollo) viene condivisa tra i thread di packet processing tramite un `RwLock`. La maggior parte dei pacchetti fa solo lookup di connessioni già stabilite (`read()`), mentre l'aggiunta di una nuova connessione richiede un blocco esclusivo (`write()`) di brevissima durata.
- Per eliminare la contesa di lock sotto elevati volumi di traffico (multi-gigabit), si preferisce un'architettura lock-free basata su `crossbeam::epoch` o tabelle partizionate per core CPU (con `AtomicU64` per i timestamp di timeout).
- `std::sync::mpsc::sync_channel`: Per inoltrare i pacchetti sospetti o violazioni di policy a un sottosistema di logging/alerting asincrono senza degradare la latenza del piano di inoltro dati principale.